

Gap Analysis Report – EdTech Study Platform vs. SRS v7.3

Current State Summary

The platform has a solid, feature-rich core. The backend (Express + Drizzle + PostgreSQL), the frontend (React + Vite + Tailwind), the exam engine, gating logic, dashboard, and admin panel are all substantially implemented. The architecture is clean and well-structured. However, several SRS requirements – some of them security-critical – are missing or incomplete.

CRITICAL – Production Blockers

C-01 · JWT_SECRET not set as a secret

Impact: JWTs are signed with an undefined/fallback key. Any token signed today becomes invalid or insecure when the server restarts or if the key ever changes. A forged token could grant unauthorized access.

File to act on: Replit Secrets panel → add JWT_SECRET (a long random string, ≥ 64 chars).

Backend reference: artifacts/api-server/src/lib/auth.ts – the signToken and verifyToken functions read from process.env.JWT_SECRET.

C-02 · RESEND_API_KEY not configured – email verification is silently skipped

Impact: Without this key, sendVerificationEmail logs a warning and returns. Every new user who registers cannot receive a verification email, so they are permanently locked out of the platform (login requires emailVerified = true, per SRS FR-AUTH-02, AC-AUTH06).

File to act on: Replit Secrets panel → add RESEND_API_KEY (from resend.com). Also set FROM_EMAIL to a verified sender domain.

Backend reference: artifacts/api-server/src/lib/email.ts lines 1–4.

C-03 · B2 credentials not configured – all file operations fail silently

Impact: PDF note uploads, PDF downloads, profile photo uploads, and profile photo removal all call into Backblaze B2 using empty strings for credentials. Every presigned URL request will either throw or return a broken URL at runtime.

Secrets to add: B2_APPLICATION_KEY_ID, B2_APPLICATION_KEY, B2_BUCKET_NAME, B2_ACCOUNT_ID.

Backend reference: artifacts/api-server/src/lib/b2.ts lines 5–8.

HIGH – Core Feature Gaps

H-01 · Client-side image compression is missing (FR-PROF-01, AC-PROF03)

Impact: SRS mandates images are compressed to ≤500KB and resized to 500×500px client-side before upload. The current code in artifacts/edtech-platform/src/pages/profile.tsx only validates file type and rejects files over 2MB – it uploads the raw original to B2. A user uploading a 1.9MB DSLR photo will store it at full resolution, burning B2 storage.

File to modify: artifacts/edtech-platform/src/pages/profile.tsx
→ handlePhotoUpload. Add a canvas-based resize/compress step using the browser Canvas API before calling getUploadUrlMutation.

H-02 · No PWA manifest or Service Worker (C-07, NFR-COMP-04, NFR-REL-01)

Impact: The SRS requires offline-first architecture: exam answers persisted to IndexedDB, the timer running in the background, and core content cached by a service worker. None of this exists. If a student loses network mid-exam and the API calls fail, their answers are not recoverable.

Files to create/modify:

- artifacts/edtech-platform/public/manifest.json – PWA manifest
 - artifacts/edtech-platform/public/sw.js – Service Worker (cache-first for static assets, background sync queue for answer saves)
 - artifacts/edtech-platform/src/pages/exam-interface.tsx – add IndexedDB write on every answer change (use idb or Dexie.js)
 - artifacts/edtech-platform/vite.config.ts – register vite-plugin-pwa
-

H-03 · Exam timer is client-side only – no server sync (C-13, NFR-SEC-05, EX-02)

Impact: The SRS explicitly requires server-side time sync to prevent cheating (C-13: Exam timer must sync server-client). The current exam-interface.tsx tracks time purely in a useState counter – a student can manipulate it via browser DevTools. The server stores remainingSeconds on pause/resume but never

validates elapsed time on submit.

File to modify: artifacts/api-server/src/routes/exams.ts → POST /exam/:id/submit should calculate authoritative remaining time from startTime + durationMinutes and reject if the client-provided answers arrive after the server-computed deadline.

H-04 · No tab-switch detection or anti-cheat warnings (EX-09, AC-EX28, NFR-SEC-05)

Impact: SRS requires the Visibility API to detect tab switching and warn the user during exams. Not implemented.

File to modify: artifacts/edtech-platform/src/pages/exam-interface.tsx – add
document.addEventListener('visibilitychange', ...) handler; show a toast/warning when document.hidden becomes true; optionally log the event to the server.

H-05 · Exam keyboard shortcuts not implemented (EX-08, AC-EX25)

Impact: SRS specifies Arrow Left/Right to navigate questions, M to mark for review, Enter to save & next. None are wired up.

File to modify: artifacts/edtech-platform/src/pages/exam-interface.tsx – add a keydown event listener (guard with !event.target.matches('input, textarea') so typing isn't intercepted).

H-06 · Exam pause limit not enforced (EX-02)

Impact: SRS allows a configurable max number of pauses per exam (e.g., 2). Currently a student can pause/resume indefinitely,

which breaks exam integrity.

Files to modify:

- lib/db/src/schema/exams.ts – add maxPauses column (already may exist in system_config)
 - artifacts/api-server/src/routes/exams.ts – POST /exam/pause – check pause count against limit, return 403 if exceeded
 - artifacts/edtech-platform/src/pages/exam-interface.tsx – show remaining pauses in the UI
-

H-07 · resend-verification endpoint has no per-user rate limit (AC-AUTH08)

Impact: SRS specifies max 3 resend attempts per hour. The global IP limiter (120 req/min) covers broad abuse but does not enforce per-user/per-email cooldowns. An attacker could repeatedly trigger resend to spam a victim's inbox.

File to modify: artifacts/api-server/src/app.ts – add a dedicated limiter on POST /api/auth/resend-verification (max 3/hr keyed by email/IP), similar to the existing authLimiter.

H-08 · Admin has no gate configuration UI (FR-AD02, AC-AD03/04)

Impact: The system_config table exists in the schema, but there is no admin UI to configure passing score thresholds, retry limits, or difficulty levels. These are currently hardcoded in route logic. Admins cannot change gating rules without a code deployment.

Files to create/modify:

- artifacts/edtech-platform/src/pages/admin-settings.tsx – add a "Gate Configuration" section that reads/writes

system_config rows

- artifacts/api-server/src/routes/admin.ts – add GET/PUT /admin/config endpoints
-

H-09 · QR codes not auto-generated on admin video URL save (EX-07, AC-EX21)

Impact: SRS states "QR codes are generated automatically upon saving a video URL." The qrcode npm package is already installed, but the admin question form saves videoUrl without generating a QR SVG/PNG. The results page reads qrCodeSvg from question data – if it's null, no QR is shown.

File to modify: artifacts/api-server/src/routes/questions.ts – on POST and PATCH, if videoUrl is provided, call qrcode.toString(videoUrl, { type: 'svg' }) and persist to a qrCodeSvg column in the questions table.

H-10 · Audit log not written on role changes (FR-B00T-02, AC-B06)

Impact: The audit_logs table exists, but role promotion/demotion through the admin users page needs to be verified as writing an audit record. The SRS requires every role change to be logged with actor, target, old role, new role, and timestamp.

File to verify/modify: artifacts/api-server/src/routes/admin.ts – confirm that role change endpoints insert into audit_logs.

● MEDIUM – Important UX/Feature Gaps

M-01 · Study Planner auto-task generation not implemented (FR-PLAN-01, AC-PL01)

Impact: The SRS requires a daily cron job at 00:00 UTC that fetches weak topics and spaced repetition due tasks, then generates 3-5 auto tasks per user. Only manual tasks work today.

File to create: artifacts/api-server/src/lib/study-planner-cron.ts – implement the logic; schedule it in artifacts/api-server/src/index.ts with setInterval (similar to the existing sweepExpiredAttempts call).

M-02 · Study Planner has no drag-and-drop reordering (FR-PLAN-02, AC-PL04)

File to modify: artifacts/edtech-platform/src/pages/planner.tsx – add drag-and-drop using @dnd-kit/core (already a common pattern in the stack). Add a PATCH /tasks/:id/reorder endpoint.

M-03 · Pomodoro timer has no background (Service Worker) support (FR-POM0-01, AC-P02)

Impact: The timer resets when the tab is hidden or the browser throttles it. Requires the Service Worker from H-02 to be implemented first.

M-04 · Pomodoro has no topic context association (FR-POM0-03, AC-P05)

Impact: When the Pomodoro is started from a topic page, the session should be tagged to that topic. Currently createSession

always sends durationSeconds only.

File to modify: artifacts/edtech-platform/src/components/pomodoro.tsx – accept an optional topicId prop; pass it through to the session creation API.

M-05 · Dashboard missing focus streak display (Section 7.1.3)

Impact: SRS specifies a "🔥 5 Days" streak and "Today's Focus: 45 mins / 2h Goal" in the top bar. Pomodoro sessions are logged but this data is not surfaced in the dashboard.

Files to modify: artifacts/api-server/src/routes/dashboard.ts – add streak + today's focus minutes to the summary response.
artifacts/edtech-platform/src/pages/dashboard.tsx – render the streak and focus goal widgets.

M-06 · Welcome email not sent on registration (Section 7.3.5)

Impact: SRS lists a "Welcome" transactional email triggered on registration. Only the verification email is sent.

File to modify: artifacts/api-server/src/routes/auth.ts – after insert, call a new sendWelcomeEmail() function (to be added to artifacts/api-server/src/lib/email.ts).

M-07 · Storage monitoring / alert job not scheduled (FR-NOT-01 trigger)

Impact: sendStorageAlertEmail is implemented but never called. The SRS requires an alert when B2 usage exceeds 8GB. There is no background job querying B2 usage.

File to create: artifacts/api-server/src/lib/storage-monitor.ts

- query B2 bucket size, compare against threshold, email the admin. Schedule in index.ts.

M-08 · Web Push notifications not implemented (FR-NOT-01)

Impact: In-app (bell icon) notifications exist. Browser push notifications for "Daily Plan ready", "Streak about to break", and "Exam starting soon" are not implemented.

Files to create: Push subscription endpoint (POST /api/notifications/subscribe), Service Worker push handler (blocked by H-02 anyway).

M-09 · Notification preferences UI not implemented (FR-NOT-02)

File to modify: artifacts/edtech-platform/src/pages/profile.tsx
– add a "Notification Preferences" section with toggles for daily plan reminders and streak reminders.

M-10 · Emergency super-admin recovery mechanism absent (FR-BOOT-03)

Impact: If the sole super-admin loses access, there is no documented recovery path beyond direct database intervention.

File to create: artifacts/api-server/src/routes/admin.ts – add a POST /admin/recover endpoint gated by a RECOVERY_SECRET environment variable (stored as a Replit secret, never in code).

● LOW – Deferred / Enhancement Items

ID	Gap	SRS Ref
L-01	Cloudflare CDN in front of B2 for egress reduction	AC-P09, FR-P02
L-02	In-app QR camera scanner (currently QR codes are just SVG images)	EX-05, AC-EX16
L-03	Sentry error monitoring integration	NFR-REL-02
L-04	Admin drag-and-drop video mapping UI	EX-07
L-05	Percentile calculation against other users on result screen	EX-03
L-06	Spaced repetition engine for auto task generation	FR-PLAN-01
L-07	Lecture analytics (CTR < 10% flag in admin)	FR-T02, AC-T06
L-08	PATCH /exam/:id to allow admin to edit existing exam metadata	EX-07

Secrets Currently Missing

Secret	Required For	Risk If Missing
JWT_SECRET	Token signing	CRITICAL – auth is insecure

Secret	Required For	Risk If Missing
RESEND_API_KEY	Email verification	CRITICAL – all users locked out
B2_APPLICATION_KEY_ID	File uploads/downloads	CRITICAL – notes/photos broken
B2_APPLICATION_KEY	File uploads/downloads	CRITICAL – notes/photos broken
B2_BUCKET_NAME	File uploads/downloads	CRITICAL – notes/photos broken
B2_ACCOUNT_ID	File uploads/downloads	CRITICAL – notes/photos broken

Recommended Implementation Roadmap

PHASE 1 – Secrets & Security (Day 1, ~2 hours)

1. Set JWT_SECRET, RESEND_API_KEY, all B2 secrets in Replit Secrets
2. Add resend-verification rate limiter (H-07)
3. Add server-side time validation on exam submit (H-03)
4. Add QR auto-generation on video URL save (H-09)
5. Confirm audit log writes on role changes (H-10)

PHASE 2 – Exam Integrity & UX (Days 2–4, ~1.5 days)

6. Client-side image compression on profile photo upload (H-01)
7. Tab-switch detection in exam interface (H-04)

8. Keyboard shortcuts in exam (H-05)
9. Exam pause limit enforcement (H-06)
10. Admin gate configuration UI (H-08)

PHASE 3 – PWA & Offline (Days 5–7, ~2 days)

11. PWA manifest + vite-plugin-pwa (H-02)
12. Service Worker with offline answer cache (H-02)
13. IndexedDB answer persistence in exam interface (H-02)
14. Pomodoro background timer via SW (M-03)

PHASE 4 – Smart Features (Days 8–11, ~2 days)

15. Daily study planner cron job (M-01)
16. Dashboard focus streak + today's goal (M-05)
17. Pomodoro topic context tagging (M-04)
18. Welcome email on registration (M-06)
19. Storage monitoring + alert job (M-07)
20. Task drag-and-drop reorder (M-02)

PHASE 5 – Polish (Days 12–14, ~1 day)

21. Emergency recovery endpoint (M-10)
22. Notification preferences UI (M-09)
23. Web Push notifications (M-08)
24. Sentry integration (L-03)
25. Cloudflare CDN setup (L-01)

